DETECÇÃO DO SPYWARE PEGASUS E ANOMALIAS DE REDE VIA NAIVE BAYES

APLICAÇÃO DE APRENDIZADO PROBABILÍSTICO EM CIBERSEGURANÇA

DESENVOLVIDO POR: GIAN LUCCA PANZONE

CONTEXTUALIZAÇÃO E OBJETIVO

CONTEXTO

SPYWARES MODERNOS (EX: PEGASUS) REALIZAM EXFILTRAÇÃO SILENCIOSA DE DADOS EM DISPOSITIVOS MÓVEIS E CORPORATIVOS, EXIGINDO TRIAGEM CONTÍNUA DE TELEMETRIA DE REDE.

OBJETIVO

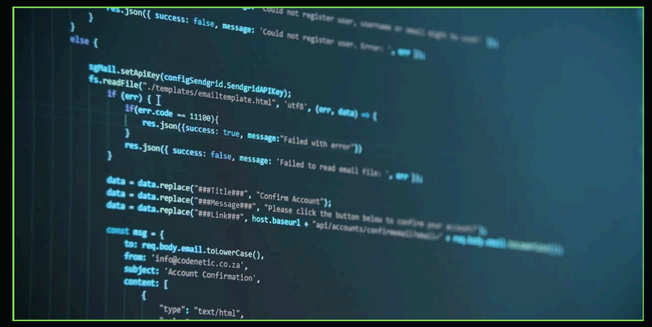
CONSTRUIR UM CLASSIFICADOR PROBABILÍSTICO SUPERVISIONADO PARA PREVER SE UM EVENTO DE TELEMETRIA É BENIGNO OU PARTE DE UMA INTRUSÃO MALICIOSA.

ESCOPO

AVALIAR A APLICABILIDADE, EFICÁCIA E LIMITAÇÕES DA TEORIA BAYESIANA SOB REQUISITOS DE TEMPO REAL EM UM SOC (SECURITY OPERATIONS CENTER).

O DATASET DE TELEMETRIA

DATASET DE LOGS DE TELEMETRIA COM 1.000 REGISTROS CONTENDO ATRIBUTOS DE SISTEMA E TRÁFEGO DE REDE.



ATRIBUTOS PRINCIPAIS (FEATURES X)

DISPOSITIVO E SISTEMA

- DEVICE_TYPE, OS_VERSION, APP_USAGE_PATTERN

COMUNICAÇÃO DE REDE

- PROTOCOL (HTTP, HTTPS, SSH, FTP), VOLUME_BIN (FAIXAS DE BYTES).

EXECUÇÃO DE SISTEMA

- LOG_TYPE, EVENT, PROCESS, ANOMALY_DETECTED

VARIÁVEL-ALVO (Y)

TARGET_MALICIOUS

- 0 = LEGÍTIMO
- 1 = MALICIOSO / IOC PRESENTE).

...

PRÉ-PROCESSAMENTO E ENGENHARIA DE FEATURES

TRATAMENTO DE AUSENTES

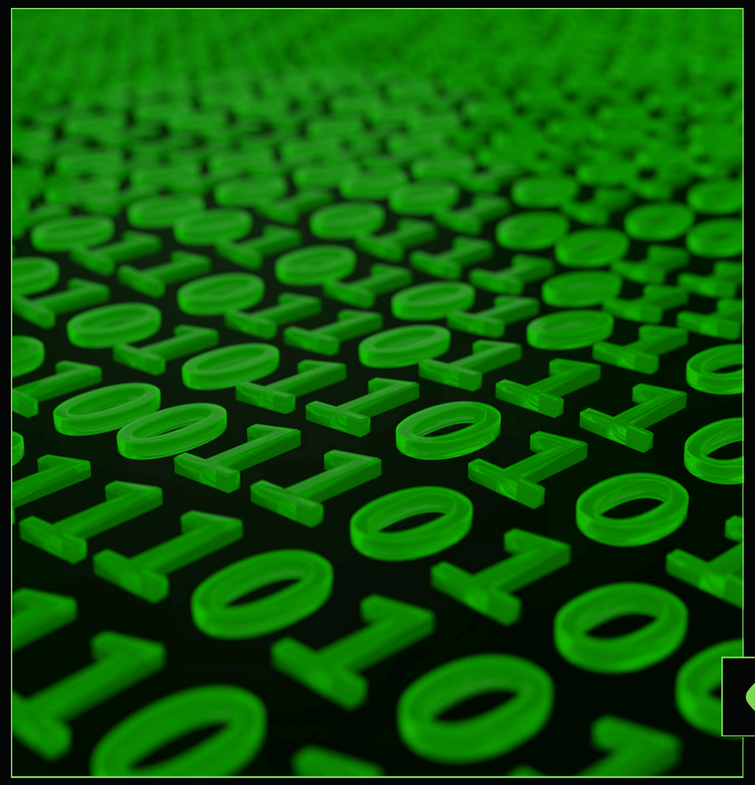
IMPUTAÇÃO DO RÓTULO 'NONE' NA VARIÁVEL ANOMALY_DETECTED (AUSÊNCIA DE ALERTAS AUTOMÁTICOS DO SISTEMA).

CODIFICAÇÃO CATEGÓRICA

MAPEAMENTO DE RÓTULOS TEXTUAIS PARA ÍNDICES NUMÉRICOS REQUERIDOS PELOS ESTIMADORES DO SCIKIT-LEARN.

DISCRETIZAÇÃO POR QUARTIS

(PD.QCUT): CONVERSÃO DO VOLUME CONTÍNUO DE BYTES (DATA_VOLUME) EM 4 CATEGORIAS (BAIXO, MÉDIO-BAIXO, MÉDIO-ALTO, ALTO).



FUNDAMENTAÇÃO TEÓRICA

NAIVE BAYES

PRINCÍPIO PROBABILÍSTICO

BASEADO NO TEOREMA DE BAYES PARA CALCULAR A PROBABILIDADE A POSTERIORI P({MALICIOSO} | {EVIDÊNCIAS}).

ESCOLHA DA VARIANTE

JUSTIFICADA PELA ESTRUTURA DOS DADOS, ONDE 100% DOS ATRIBUTOS PREDITORES SÃO QUALITATIVOS/DISCRETOS APÓS A ENGENHARIA DE RECURSOS.

HIPÓTESE DE INDEPENDÊNCIA CONDICIONAL:

$$P(X_1, X_2 \mid Y) = P(X_1 \mid Y) * P(X_2 \mid Y)$$

...

CONFIGURAÇÃO DO EXPERIMENTO

- **DIVISÃO DOS DADOS**: 70% PARA TREINAMENTO (700 AMOSTRAS) E 30% PARA TESTE (300 AMOSTRAS).
- **AMOSTRAGEM ESTRATIFICADA**: MANTÉM A PROPORÇÃO EXATA DA CLASSE MALICIOSA ENTRE TREINO E TESTE.
- **PARÂMETRO DE SUAVIZAÇÃO**: UTILIZAÇÃO DE ALPHA = 1.0 (SUAVIZAÇÃO DE LAPLACE) PARA EVITAR O PROBLEMA DE PROBABILIDADE ZERO (ZERO-FREQUENCY PROBLEM) EM COMBINAÇÕES.DE CATEGORIAS NÃO OBSERVADAS NO TREINO.

01100011 01110010 01101001 01110000 01110100 01101111

MATRIZ DE CONFUSÃO E INTERPRETAÇÃO DE ERROS

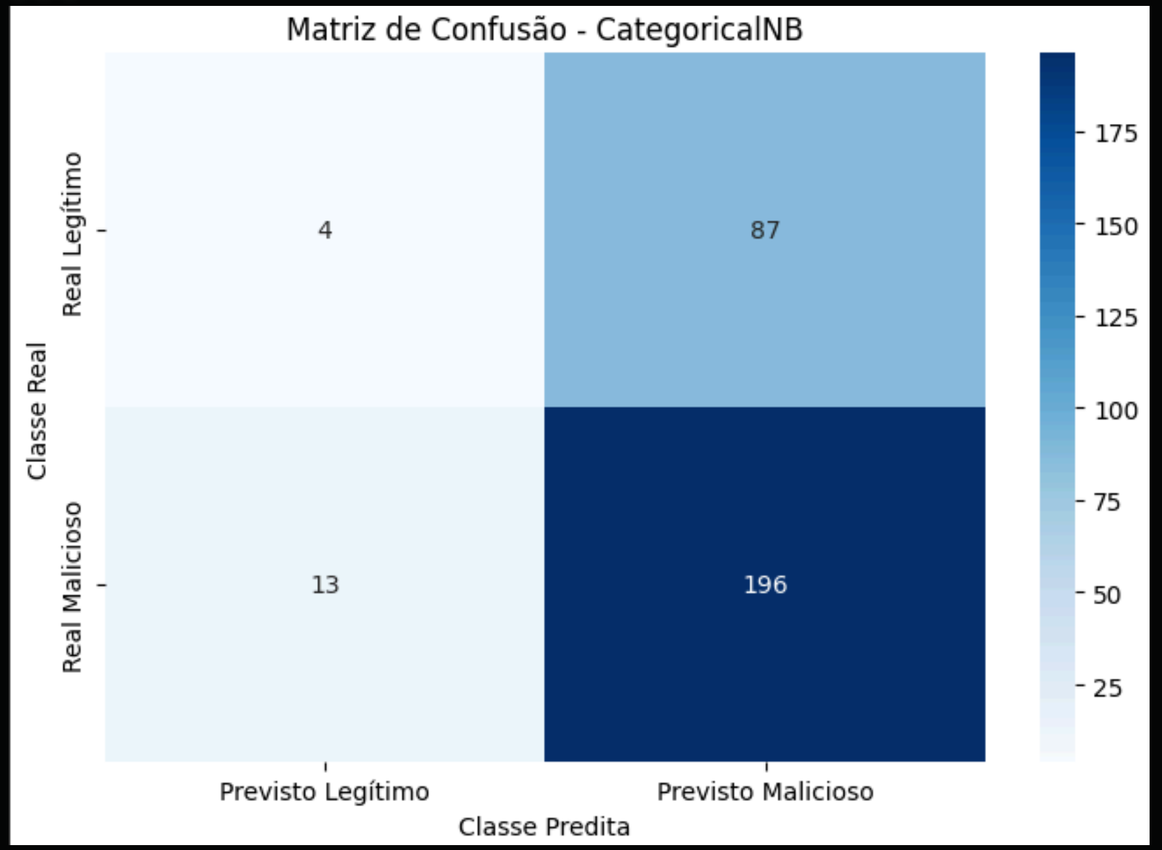
RECALL:93,78%

196 DE 209 INVASÕES ATIVAS IDENTIFICADAS E BLOQUEADAS PELO MODELO

- TP = 196 | FP = 87
- FN = 13 | TN = 4

FALSOS NEGATIVOS (FN = 13): AMEAÇAS QUE USARAM PROTOCOLOS LEGÍTIMOS (HTTPS) E BAIXO VOLUME DE DADOS, PASSANDO DESPERCEBIDAS.

FALSOS POSITIVOS (FP = 87): TRÁFEGO BENIGNO QUE UTILIZOU PROTOCOLOS NÃO USUAIS OU VOLUMES MAIS ALTOS E ACABOU MARCADO COMO SUSPEITO.



ANÁLISE CRÍTICA DO MODELO

LIMITAÇÕES E DESAFIOS:

- ALTA TAXA DE FALSOS ALARMES DEVIDO À SIMPLIFICAÇÃO DA INDEPENDÊNCIA DE ATRIBUTOS.
- VULNERÁVEL A TÉCNICAS DE EVASÃO REFINADAS QUE IMITAM PERFEITAMENTE A DISTRIBUIÇÃO DO TRÁFEGO LEGÍTIMO.

VANTAGENS DO NAIVE BAYES:

- PROCESSAMENTO EXTREMAMENTE RÁPIDO (IDEAL PARA FILTRAGEM DE GRANDE VOLUME DE LOGS EM TEMPO REAL).
- ALTA SENSIBILIDADE (RECALL ELEVADO), MINIMIZANDO A ENTRADA DE SPYWARES NA REDE SEM TRIAGEM.

...

CONCLUSÃO

O CATEGORICAL NAIVE BAYES SE PROVOU UMA FERRAMENTA VIÁVEL E EFICIENTE PARA ATUAÇÃO COMO PRIMEIRA CAMADA DE DEFESA (TRIAGEM DE ALERTAS) EM CENTROS DE OPERAÇÕES DE SEGURANÇA (SOC).

AGRADECEMOS A ATENÇÃO DE TODOS

PERGUNTAS?